

Analyse des risques de sécurité

Méthode EBIOS Risk Manager (ANSSI) — version adaptée au projet MediPlan

Ce document identifie, qualifie et hiérarchise les risques pesant sur la future plateforme de prise de rendez-vous médicaux MediPlan, qui traite des données de santé à caractère personnel (catégorie particulière au sens de l'art. 9 du RGPD). L'analyse suit la logique des ateliers EBIOS Risk Manager publiée par l'ANSSI, dans une forme simplifiée adaptée à un projet de cadrage scolaire. Elle couvre les risques de sécurité **et** les risques projet non-techniques, aboutit à une matrice de risques visuelle et désigne le risque critique retenu pour le Proof of Concept (POC) technique.

RÉFÉRENTIEL	ÉCHELLES	PÉRIMÈTRE	DATE
EBIOS RM — ANSSI	Gravité G1–G4 · Vraisemblance V1–V4	Application web MediPlan (MVP)	17/06/2026 · v2.0

1. Cadrage — socle de l'étude (Atelier 1)

Le cadrage délimite ce que l'on protège. Les **valeurs métier** sont les processus et informations essentiels au service ; les **biens supports** sont les composants techniques sur lesquels elles reposent ; les **événements redoutés** décrivent ce qui arriverait si une valeur métier était atteinte.

Valeur métier	Biens supports associés	Événement redouté · Gravité
Dossier patient & données de santé	PostgreSQL (HDS), API NestJS, sauvegardes	Divulgateion / altération de données de santé — G4 Critique
Prise de RDV en ligne	Frontend React, API, hébergement OVHcloud HDS	Indisponibilité du service de réservation — G2
Authentification & gestion des accès	Keycloak (IAM), annuaire des comptes	Usurpation d'identité / accès illégitime — G3 Grave
Notifications (rappels e-mail / SMS)	Service de notification, passerelle SMS/SMTP	Fuite d'information via un rappel mal adressé — G2
Conformité réglementaire (RGPD/HDS)	Hébergeur certifié HDS, registre, AIPD	Non-conformité, sanction CNIL — G3 Grave

2. Sources de risque (Atelier 2)

Les sources de risque sont les acteurs ou phénomènes susceptibles de déclencher un événement redouté. Chacune est caractérisée par sa **motivation** (objectif visé) et sa **capacité** (moyens dont elle dispose). La valeur élevée des données de santé — un dossier médical se revend environ 250 € sur les marchés illégaux — accroît l'attractivité de MediPlan pour les sources externes.

Source de risque	Motivation / objectif visé	Capacité	Cible prioritaire
Cybercriminel externe	Revente de données de santé, rançongiciel	Élevée	R1, R7
Personnel interne malveillant	Vengeance, profit, exfiltration	Moyenne	R1, R2
Erreur humaine (interne)	Inattention, hameçonnage réussi	Élevée	R2, R6
Concurrent / activiste (« hacktiviste »)	Atteinte à l'image, indisponibilité	Moyenne	R3
Défaut technique / fournisseur	Panne, faille logicielle, prestataire défaillant	Moyenne	R3, R4
Organisation projet (interne)	Sous-estimation, conduite du changement faible	N/A	R8, R9

3. Échelles de cotation

Vraisemblance (V)	Gravité (G)
V1 Minime — peu probable (< 10 %)	G1 Mineure — gêne limitée
V2 Significative — peut survenir (10–40 %)	G2 Significative — impact notable
V3 Forte — probable (40–70 %)	G3 Grave — atteinte sérieuse (données, conformité)
V4 Maximale — quasi certaine (> 70 %)	G4 Critique — atteinte massive aux données / arrêt du service

Criticité = Vraisemblance × Gravité. Niveaux retenus : **Faible 1–3** **Modéré 4–6** **Élevé 8–9** **Critique 12–16**

4. Scénarios de risque qualifiés (Ateliers 3 & 4)

Neuf scénarios sont retenus (minimum 5 requis) : sept de nature sécurité (R1–R7) et deux de nature projet (R8–R9). Chacun est décrit par sa **cause** (élément déclencheur), sa **source** de risque (cf. atelier 2) et son **impact**, puis coté en vraisemblance (V) et gravité (G). Chaque cote est justifiée à partir d'éléments concrets (sensibilité des données, statistiques sectorielles, maturité du projet).

ID	Scénario — cause, source, impact & justification	V	G	V×G	Niveau
R1	Fuite / exfiltration de données de santé Cause : base mal protégée, dump SQL exposé, injection réussie. Source : cybercriminel externe ; interne malveillant. Impact : divulgation massive de données sensibles, sanction CNIL ($\leq 4\%$ du CA), perte de confiance. <i>V3 : cible à très forte valeur (dossier ≈ 250 €), attaques fréquentes en santé. G4 : atteinte massive aux données sensibles.</i>	V3	G4	12	Critique
R2	Compromission d'un compte soignant / secrétariat Cause : hameçonnage, mot de passe faible, absence de MFA. Source : cybercriminel externe ; erreur humaine interne. Impact : accès illégitime aux dossiers du compte, actions frauduleuses au nom de l'agent. <i>V3 : l'hameçonnage est le 1^{er} vecteur d'intrusion en santé. G3 : accès grave mais limité au compte compromis.</i>	V3	G3	9	Élevé
R3	Indisponibilité du service de réservation	V2	G2	4	Modéré

Cause : attaque DDoS, panne de l'hébergeur, bug critique en production.
Source : concurrent / hacktiviste ; défaut technique / fournisseur.
Impact : patients ne pouvant plus réserver, atteinte à l'image de l'hôpital.
V2 : possible mais atténué par l'hébergement HDS redondé. G2 : gêne le service sans atteinte aux données.

R4 Injection / faille applicative (SQLi, IDOR) V2 G4 8 Élevé

Cause : entrée non validée, contrôle d'autorisation manquant, requête non paramétrée.
Source : cybercriminel externe ; défaut technique.
Impact : lecture/modification de dossiers d'autres patients, exposition de la base.
V2 : risque réel sur une appli web jeune, réduit par l'ORM et la revue de code. G4 : une faille IDOR peut exposer tous les dossiers.

R5 Non-conformité RGPD / HDS V2 G3 6 Modéré

Cause : hébergement non certifié, absence de consentement, droit à l'oubli non implémenté.
Source : organisation projet ; défaut de conception.
Impact : sanction CNIL, suspension du traitement, illégalité de l'hébergement.
V2 : exigences nombreuses, oubli possible en phase MVP. G3 : suspension possible du traitement, sanction CNIL.

R6 Fuite via une notification (rappel mal adressé) V2 G2 4 Modéré

Cause : mauvais destinataire, contenu trop détaillé dans le rappel SMS/e-mail.
Source : erreur humaine ; défaut de conception du module notif.
Impact : divulgation d'une information de RDV à un tiers, atteinte à la vie privée.
V2 : erreur d'adressage plausible. G2 : fuite limitée si le contenu reste minimal (pas de détail médical).

R7 Perte de données / rançongiciel V1 G4 4 Modéré

Cause : chiffrement malveillant, absence ou non-test des sauvegardes.
Source : cybercriminel externe ; défaut technique.
Impact : perte irréversible des dossiers patients, arrêt prolongé du service.
V1 : peu probable avec une politique de sauvegarde, mais impact maximal sinon. G4 : perte irréversible des dossiers.

R8 Résistance au changement des utilisateurs V3 G2 6 Modéré

Cause : habitude de l'ancien outil, conduite du changement insuffisante, formation absente.
Source : organisation projet ; utilisateurs internes.
Impact : faible adoption, système contourné, bénéfice du projet non atteint.
V3 : changement d'outil métier, adoption rarement spontanée. G2 : non-adoption sans atteinte aux données.

R9 Dépassement de budget / délai V2 G2 4 Modéré

Cause : sous-estimation, dérive du périmètre, dépendances externes (certification HDS).
Source : organisation projet.
Impact : retard de livraison, surcoût, voire arrêt du projet.
V2 : risque classique, atténué par un périmètre MVP cadré. G2 : retard sans conséquence sur la sécurité.

5. Matrice de risques

Vraisemblance ↑	V4				
	V3		R8	R2	R1
	V2		R3 R6 R9	R5	R4
	V1				R7
		G1	G2	G3	G4
		Gravité →			

■ Faible
 ■ Modéré
 ■ Élevé
 ■ Critique

Lecture : R1 (fuite de données de santé) est le seul risque en zone critique ($V3 \times G4 = 12$). Il est retenu comme point le plus risqué pour le POC technique : démontrer la faisabilité du chiffrement applicatif des données sensibles au repos et du cloisonnement des accès, de sorte qu'un dump de la base reste inexploitable. R3, R6 et R9 partagent la case $V2 \times G2$.

6. Plan de traitement du risque (Atelier 5)

Pour chaque risque : une **stratégie** (éviter, réduire, transférer, accepter), des **actions** concrètes, un **responsable** et un **délai**. Le risque résiduel est la criticité attendue après application des mesures.

ID	Stratégie	Mesures de mitigation	Responsable	Délai	Résiduel
R1	Réduire	Chiffrement des données sensibles au repos (column-level + disque HDS), TLS 1.3 en transit, RBAC strict (cloisonnement médecin/secrétariat), journalisation des accès, sauvegardes chiffrées, tests de pénétration.	Analyste Technique / RSSI	Avant mise en production	V2×G3 — Modéré
R2	Réduire	MFA obligatoire via Keycloak, politique de mots de passe, détection des connexions anormales, sensibilisation au hameçonnage, expiration des sessions.	Analyste Technique	Sprint sécurité (avant prod)	V2×G2 — Modéré
R3	Transférer	Hébergement HDS redondé, autoscaling, rate-limiting / anti-DDoS, supervision et plan de continuité (responsabilité partagée avec l'hébergeur).	Hébergeur HDS / Ops	Mise en place infra	V1×G2 — Faible
R4	Réduire	Requêtes paramétrées (ORM), validation des entrées, contrôle d'autorisation systématique (anti-IDOR), tests de sécurité et revue de code.	Analyste Technique / Dev	Continu (chaque sprint)	V1×G4 — Modéré
R5	Réduire	Hébergeur certifié HDS, registre des traitements, AIPD, consentement explicite, purge automatique (droit à l'oubli), DPO désigné.	DPO / Chef de Projet	Avant collecte de données réelles	V1×G2 — Faible
R6	Réduire		Analyste Technique		V1×G2 — Faible

		Vérification du destinataire, contenu minimal dans les rappels (pas de détail médical), double opt-in, chiffrement des canaux SMTP.		Conception du module notif.	
R7	Réduire	Sauvegardes chiffrées hors-ligne (règle 3-2-1), tests de restauration, EDR / anti-rançongiciel, segmentation réseau.	Ops / RSSI	Avant mise en production	V1×G3 — Modéré
R8	Réduire	Formation des utilisateurs (2 sessions min.), documentation illustrée, phase pilote sur périmètre restreint, référent identifié par équipe.	Chef de Projet	1 mois avant déploiement	V1×G2 — Faible
R9	Réduire / Accepter	Périmètre MVP figé, suivi Gantt + jalons, gestion des dépendances HDS, marge de contingence ; risque résiduel accepté car non lié à la sécurité.	Chef de Projet	Suivi continu	V1×G2 — Faible

7. Conclusion — risque retenu pour le POC

L'analyse fait ressortir **R1 — fuite de données de santé** comme risque critique unique et structurant pour le projet (criticité 12). Le POC technique devra donc prouver la faisabilité de sa principale mesure de réduction : le **chiffrement applicatif des données de santé au repos couplé à un contrôle d'accès RBAC**, afin qu'un accès non autorisé à la base (vol de dump) ne permette pas de lire les informations sensibles. Les risques R2 et R4 (zone « Élevé ») feront l'objet de mesures de conception documentées dans le CDC technique, sans nécessiter de preuve de concept dédiée. Les risques projet R8 et R9 relèvent du pilotage (Chef de Projet) et non de la technique.

8. Sources

Référence	Émetteur	Usage dans le document
EBIOS Risk Manager — méthode et guide	ANSSI — anssi.gouv.fr	Cadre méthodologique : ateliers, échelles G/V, traitement du risque
RGPD — Règlement (UE) 2016/679, art. 9	Union européenne / CNIL	Qualification des données de santé comme sensibles (R1, R5)
Guide « Données de santé » et modèle d'AIPD	CNIL — cnil.fr	Obligations de protection, consentement, droit à l'oubli (R5)
Référentiel de certification HDS	Agence du Numérique en Santé (ANS) — esante.gouv.fr	Exigence d'hébergement certifié des données de santé (R5)
Code de la santé publique, art. L1111-8	Légifrance — legifrance.gouv.fr	Fondement légal de l'obligation d'hébergement HDS
OWASP Top 10 — risques applicatifs web	OWASP Foundation — owasp.org	Identification des failles applicatives : injection, IDOR (R4)